

**MEDICARE CONNECT (PTY) LTD
INTERNAL ISMS & POPIA AUDIT REPORT**

Engagement ID: AUD-2026-Q1

Audit Criteria: ISO/IEC 27001:2022 Clauses 4–10, Annex A & POPIA (Act 4 of 2013)

Classification: Confidential - For Management Action Only

Date: March 2026

Lead Auditor: Patrick Mohlala

Distribution: Board Audit Committee, CEO, IT Manager, Information Officer

1. EXECUTIVE SUMMARY

An internal ISMS and POPIA compliance audit was conducted for MediCare Connect (Pty) Ltd in March 2026.

The audit evaluated whether the ISMS conforms to ISO 27001:2022 requirements and operates effectively to safeguard patient health information under South African law.

OVERALL AUDIT OPINION: PROVISIONAL / CONDITIONAL READINESS

The ISMS framework demonstrates strong foundational design across policies, risk assessment, and incident planning. However, full operational readiness is Conditional upon closing 2 Major Non-Conformities and 4 Minor Non-Conformities prior to external certification auditing.

2. SUMMARY OF AUDIT FINDINGS

FINDING BREAKDOWN BY SEVERITY	
Major Non-Conformities (NC)	2 (Immediate Action)
Minor Non-Conformities (NC)	4 (Action in 30 Days)
Opportunities for Improvement	3 (Action in 90 Days)
Total Findings	9

3. DETAILED NON-CONFORMITY REPORTS (NCRs)

MAJOR NON-CONFORMITY 01 (NCR-01)

- Standard/Ref: POPIA Section 55 & ISO 27001 Clause 5.3 / Control A.5.2
- Finding: No Information Officer has been formally appointed or registered with the Information Regulator of South Africa.
- Objective Evidence: Information Regulator portal search confirms no registration record for MediCare Connect.
- Business Impact: Statutory violation of POPIA. Directors carry personal legal liability. Organization cannot legally process personal information or handle data subject complaints.
- Severity: MAJOR NON-CONFORMITY

MAJOR NON-CONFORMITY 02 (NCR-02)

- Standard/Ref: ISO 27001:2022 Control A.8.24 (Use of Cryptography) & POPIA Section 19
- Finding: 12 out of 35 staff laptops processing patient records do not have BitLocker full-disk encryption active.
- Objective Evidence: Sample review of 35 Microsoft Intune compliance reports identified 12 unencrypted endpoints.

- Business Impact: High risk of data breach in the event of device loss or theft, triggering mandatory POPIA Section 22 public disclosure and fines up to R10 million.
- Severity: MAJOR NON-CONFORMITY

MINOR NON-CONFORMITY 03 (NCR-03)

- Standard/Ref: ISO 27001 Control A.5.20 & POPIA Section 21
- Finding: Tier 1 vendor PathLab SA is actively processing diagnostic data without an executed POPIA Section 21 Operator Agreement.
- Objective Evidence: Vendor contract file contains SLA v2.0 but lacks signed DPA/Operator Agreement.
- Severity: MINOR NON-CONFORMITY

MINOR NON-CONFORMITY 04 (NCR-04)

- Standard/Ref: ISO 27001 Control A.8.5 (Secure Authentication)
- Finding: Multi-Factor Authentication (MFA) is enabled for AWS Root and Microsoft 365 admins, but not enforced for general staff accessing PHRS.
- Objective Evidence: AWS IAM & M365 Conditional Access policy review shows MFA is optional for clinical user groups.
- Severity: MINOR NON-CONFORMITY

MINOR NON-CONFORMITY 05 (NCR-05)

- Standard/Ref: ISO 27001 Control A.8.13 (Information Backup)
- Finding: Backups are executed daily to AWS S3, but no restoration test has been conducted or documented in the past 12 months.
- Objective Evidence: S3 bucket logs confirm backup files exist, but backup log register contains no restoration test records.
- Severity: MINOR NON-CONFORMITY

MINOR NON-CONFORMITY 06 (NCR-06)

- Standard/Ref: ISO 27001 Control A.8.2 (User Access Rights)
- Finding: No formal quarterly access review has been documented for M365 or PHRS user accounts.
- Objective Evidence: Active Directory user list contains 3 orphan accounts belonging to former employees terminated >30 days ago.
- Severity: MINOR NON-CONFORMITY

4. AUDITOR RECOMMENDATIONS & CONCLUSION

MediCare Connect has built a commendable ISMS framework. However, external certification will fail if Major NCs (NCR-01 and NCR-02) remain open.

Management must approve the Corrective Action Plan (CAPA) immediately. A follow-up re-audit is scheduled in 30 days to verify closure.

Document Control

Lead Auditor : Patrick Mohlala | Date: March 2026
Status : Final Issued to EXCO